

PHISHING ANALYSIS LAB REPORT

Lab 6: Phishing URL Analysis Using VirusTotal, MXToolbox, and PhishTank

Home SOC Lab Series

Analyst	Josh Smith
Date	May 2, 2026
Tools	PhishTank, VirusTotal, MXToolbox
Samples Analyzed	3 verified phishing URLs
Targets Impersonated	T-Mobile, Ledger Hardware Wallet (x2)

1. LAB OVERVIEW

This lab documents a phishing URL analysis exercise conducted using three open-source intelligence tools: PhishTank for sample sourcing and WHOIS data, VirusTotal for multi-vendor threat intelligence, and MXToolbox for email authentication and DNS analysis. Three verified phishing URLs were selected from PhishTank and analyzed systematically to identify indicators of compromise, understand attacker infrastructure, and compare detection capabilities across tools.

The lab demonstrates two distinct phishing techniques: subdomain spoofing using a throwaway domain (Sample 1), and legitimate platform abuse using Wix to host phishing content (Samples 2 and 3). The contrast between these techniques highlights why URL-based detection alone is insufficient and content-level analysis is required for modern phishing defense.

2. METHODOLOGY

Each sample was processed through the following workflow:

- PhishTank: Verified phish status, community confidence score, WHOIS data, and network/hosting information
- VirusTotal: Multi-vendor URL scan for detection rate, hosting IP, HTTP response, and HTML metadata
- MXToolbox: DNS infrastructure check including MX records, SPF, DMARC, and CNAME records

All samples were sourced from PhishTank's live verified phish database on May 2, 2026. No phishing pages were visited directly — all analysis was conducted passively using the tools listed above.

3. SAMPLE 1 — T-MOBILE BRAND SPOOFING

3.1 Sample Identification

PhishTank ID	#9412749
URL	https://t-mobile.ygbhd.top/
Target	T-Mobile
Technique	Subdomain spoofing via throwaway domain
Status	Online (page returned 404 at time of analysis)
PhishTank Confidence	100% – verified by 4 community members

3.2 PhishTank Analysis

- Domain: ygbhd.top — a randomly generated domain using T-Mobile as a subdomain to appear legitimate
- Network: AS45102 — Alibaba Cloud (China). T-Mobile would never host infrastructure on Chinese cloud providers
- WHOIS Creation Date: April 28, 2026 — domain registered 4 days before analysis
- WHOIS Expiry: April 28, 2027 — registered for only one year, typical of throwaway phishing domains
- Registrant: Fully redacted for privacy
- Registrar: Gname.com (Singapore) — commonly abused by threat actors for cheap domain registration
- Domain Status: addPeriod — still within the grace period immediately after registration

3.3 VirusTotal Analysis

- Detection: 4/92 vendors flagged as malicious — very low detection rate consistent with a brand new domain
- Flagging vendors: alphaMountain.ai (Phishing), Emsisoft (Phishing), Fortinet (Phishing), Netcraft (Malicious)

- LevelBlue flagged as Suspicious
- Serving IP: 8.211.13.146 — confirms Alibaba Cloud hosting (AS45102, CN)
- Forcepoint ThreatSeeker categorized as 'newly registered websites' — a behavioral IOC
- HSTS enabled — attacker used HTTPS to appear legitimate to victims
- First submitted to VirusTotal: April 30, 2026

3.4 MXToolbox Analysis

- MX Record: Not found — no mail server configured, domain was never set up for legitimate email
- DMARC: No record found — no email authentication policy
- SPF: No record found — no sender policy configured
- Conclusion: Domain has zero email infrastructure, confirming it was registered solely to host a phishing page

3.5 Indicators of Compromise

Malicious URL	https://t-mobile.ygbhd.top/
Malicious Domain	ygbhd.top
Hosting IP	8.211.13.146
ASN	AS45102 – Alibaba Cloud, CN
Domain Age	4 days at time of detection
Registrar	Gname.com Pte. Ltd.

4. SAMPLE 2 — LEDGER WALLET PHISHING VIA WIX

4.1 Sample Identification

PhishTank ID	#9412412
URL	https://studio-desktop.wixstudio.com/live
Target	Ledger Hardware Wallet
Technique	Legitimate platform abuse — phishing page hosted on Wix
Status	Online (HTTP 200) at time of analysis
PhishTank Confidence	Verified phish

4.2 PhishTank Analysis

- URL uses a legitimate wixstudio.com subdomain — no domain spoofing required
- WHOIS privacy enabled — registrant details redacted, consistent with phishing infrastructure
- Domain passes standard reputation checks because wixstudio.com is a legitimate, trusted platform

4.3 VirusTotal Analysis

- Detection: 18/92 vendors flagged — significantly higher than Sample 1 due to the page being live and indexed
- Major vendors flagging: BitDefender, ESET, Kaspersky, Fortinet, Sophos, Webroot, G-Data, CyRadar
- Serving IP: 34.144.206.118 — legitimate Wix/Google Cloud infrastructure
- HTTP Status: 200 — page fully active
- HTML Title: 'Ledger Live: Desktop — Getting Started | official Ledger' — impersonating Ledger's official desktop application
- Meta description references managing digital assets and crypto portfolio — targeting cryptocurrency users
- Generator tag: Wix.com Website Builder — confirms the attacker built this page using Wix's drag-and-drop interface
- Content language: es-419 (Latin American Spanish) — potential indicator of threat actor region

4.4 MXToolbox Analysis

- Ran against wixstudio.com — returns valid SSL certificate, HTTP 200, all checks pass
- This is expected — the domain belongs to Wix, not the attacker
- Domain-level checks cannot detect this type of phishing — the malicious content is hosted inside a legitimate service
- Detection must occur at the content level, not the domain or email authentication level

4.5 Indicators of Compromise

Malicious URL	https://studio-desktop.wixstudio.com/live
Platform	Wix (legitimate service abused)
Hosting IP	34.144.206.118
Impersonated Brand	Ledger Live Desktop application
Target Sector	Cryptocurrency / Digital Asset holders
Content Language	es-419 (Latin American Spanish)

5. SAMPLE 3 — LEDGER WALLET PHISHING VIA WIX (CAMPAIGN CONFIRMATION)

5.1 Sample Identification

PhishTank ID	#9412413
URL	https://desktop-platforms.wixstudio.com/desktop
Target	Ledger Hardware Wallet
Technique	Legitimate platform abuse — same campaign as Sample 2
Status	Online (HTTP 200) at time of analysis

5.2 VirusTotal Analysis

- Detection: 16/92 vendors flagged — consistent with Sample 2
- Serving IP: 34.144.206.118 — identical to Sample 2, confirms shared infrastructure
- HTML Title: 'Ledger Live: Desktop — Getting Started' — identical to Sample 2
- Meta description identical to Sample 2 — copy-paste campaign deployment
- First submitted: May 2, 2026 — same day as analysis, very fresh

5.3 MXToolbox Analysis

- CNAME record: desktop-platforms.wixstudio.com → username.wix.com — reveals the attacker's Wix account identifier
- DMARC record found and Quarantine/Reject policy enabled — belongs to Wix platform, not the attacker
- DNS Record published — legitimate infrastructure
- The CNAME to username.wix.com is actionable intelligence — in a real investigation this would be submitted to Wix abuse team for account takedown

5.4 Campaign Correlation

Samples 2 and 3 share the same serving IP address (34.144.206.118), identical HTML titles and meta descriptions, the same Wix hosting infrastructure, and the same target (Ledger hardware wallet). This confirms they are part of a coordinated multi-URL phishing campaign. The attacker deployed multiple Wix subdomains targeting the same brand to maintain operational continuity — when one URL is taken down or blocked, others remain active.

5.5 Indicators of Compromise

Malicious URL	https://desktop-platforms.wixstudio.com/desktop
Platform	Wix (legitimate service abused)
Hosting IP	34.144.206.118 (shared with Sample 2)
Wix Account	username.wix.com (via CNAME)
Impersonated Brand	Ledger Live Desktop application
Campaign Link	Confirmed same campaign as Sample 2

6. EMAIL ANALYSIS — PHISHTOOL

Two phishing emails sourced from the PhishingPot open-source repository were analyzed using PhishTool to demonstrate email header analysis, authentication failure identification, and URL extraction. Both emails target cryptocurrency users and share infrastructure with the URL-based samples analyzed in Sections 3-5.

6.1 Email 1 — Stellar Foundation Staking Scam

Subject	How to become a staker
Display Name	Stellar Foundation
From Address	smtpfox-9gv31@ayurmithrawellness.com
Date	2022-11-23
Target	Stellar (XLM) cryptocurrency holders
Lure	Fake staking event offering 6 billion XLM tokens

Header Analysis

- Display name claims 'Stellar Foundation' but actual sending address is smtpfox-9gv31@ayurmithrawellness.com — a wellness website with no connection to Stellar
- Originating IP: 194.9.179.62 — rDNS resolves to deltaxhost-ptr, a generic hosting provider
- Return-Path: smtpfox-9gv31@ayurmithrawellness.com — matches sending address, confirming domain is attacker-controlled
- Message-ID generated from DESKTOP-RQ5VPH2 — suggests the email was sent from a compromised or attacker-controlled Windows workstation

Authentication Results

- SPF: None — ayurmithrawellness.com has no SPF record configured
- DKIM: Neutral — signature present but verification inconclusive
- DMARC: None — no policy exists for the domain
- All three email authentication mechanisms fail or are absent, meaning any receiving mail server with strict policy enforcement would reject or quarantine this email

URL Analysis

- Primary CTA button links to: google.com/url?q=https%3A%2F%2Fbit.ly%2F3EI6heo — double redirect through Google's URL shortener then bit.ly to hide the final destination
- Double redirect technique is used to evade URL reputation filters — the visible domain is google.com which is trusted
- Legitimate stellar.org link appears only in the disclaimer footer — used to add credibility, not connected to the malicious button
- Final destination URL unknown without clicking — the bit.ly link was not resolved during analysis to avoid visiting the phishing page

6.2 Email 2 — Celsius Network Bankruptcy Claim Scam

Subject	Reminder: Withdraw your funds today
Display Name	Claims.Celsius
From Address	ausp@mshtavr.com
Date	2023-10-04

Target	Celsius Network bankruptcy creditors
Lure	Fake 70% fund recovery claim with 72-hour deadline

Header Analysis

- Display name 'Claims.Celsius' mimics an official Celsius claims process — Celsius went bankrupt in 2022, making real victims highly susceptible to this lure
- Actual sending address: ausp@mshtavr.com — unrelated domain with no connection to Celsius Network
- Return-Path flagged red by PhishTool: tvs.mshtavr.com — subdomain mismatch from the From address
- Originating IP: 23.251.234.52 — Amazon SES infrastructure, same IP range as Email 1 (23.251.234.54), suggesting shared sending infrastructure
- Sent via Amazon SES — legitimate email service being abused, similar to the Wix platform abuse in the URL samples

Authentication Results

- SPF: None — tvs.mshtavr.com has no SPF record
- DKIM: Neutral — 2 signatures present (mshtavr.com and amazonses.com) both return neutral
- DMARC: None — no policy configured for mshtavr.com

URL Analysis

- Malicious link: https://matka.solutions/cel/ — 'matka' means lottery/gambling in several languages, completely unrelated to Celsius
- Both 'Withdraw Now' button and 'Click here to freeze your account' link go to the same matka.solutions URL — urgency tactics designed to panic victims into clicking
- Legitimate Celsius links included: help.celsius.network, celsius.network/terms-of-use, celsius.network/privacy-policy — used to make the email appear authentic
- Scraped content from flickr.com, creativecommons.org, and nhm.ac.uk injected in the email footer — a known technique to pad email content and evade spam filters by adding text from trusted domains

6.3 Email Analysis Key Findings

- Both emails target cryptocurrency users — consistent with the Ledger wallet phishing URLs analyzed in Sections 4 and 5, suggesting crypto users are a high-value target group
- Both emails use Amazon SES for delivery — legitimate cloud email infrastructure is being abused to improve deliverability and bypass IP reputation blocks
- Neither email passes SPF, DKIM, or DMARC — organizations with strict email authentication enforcement (reject policy) would have blocked both
- Both use URL obfuscation — Email 1 uses Google+bit.ly double redirect, Email 2 uses a misleading domain name (matka.solutions) combined with a /cel/ path
- Both include legitimate domain references to add credibility — stellar.org in Email 1, celsius.network in Email 2
- Urgency and scarcity tactics used in both — '72-hour deadline' and 'link can be used only once' in Email 2, 'elite club of first 25,000' in Email 1

7. COMPARATIVE ANALYSIS

7.1 Detection Rate Comparison

Sample	URL	Technique	VirusTotal Score	Domain Age	Page Status
Sample 1	t-	Subdomain	4/92 (4%)	4 days	404 — taken

	mobile.ygbhd.top	spoofing			down
Sample 2	studio-desktop.wixstudio.com/live	Platform abuse	18/92 (20%)	N/A (Wix)	200 — live
Sample 3	desktop-platforms.wixstudio.com/desktop	Platform abuse	16/92 (17%)	N/A (Wix)	200 — live

7.2 Tool Effectiveness Comparison

Tool	Sample 1	Sample 2	Sample 3	Best Used For
PhishTank	High — full WHOIS, hosting, network data	Moderate — limited WHOIS	Moderate — limited WHOIS	Domain infrastructure research
VirusTotal	Low detection (4/92)	High detection (18/92)	High detection (16/92)	Multi-vendor scoring, HTML metadata
MXToolbox	High — confirmed no email infra	Low — domain passes all checks	Moderate — reveals CNAME/Wix account	DNS, SPF, DMARC validation

7.3 Key Findings

- No single tool caught everything — each tool provided unique intelligence not available in the others
- VirusTotal detection rates were low across all samples (4-20%), confirming that relying on AV/URL filters alone is insufficient for catching new phishing infrastructure
- Sample 1 was detectable through domain analysis alone — zero-day-old domain, Chinese hosting, no email infrastructure, privacy-protected WHOIS
- Samples 2 and 3 could not be detected at the domain level — platform-abuse phishing requires content-level analysis
- MXToolbox revealed actionable threat intelligence in Sample 3 via the CNAME record pointing to the attacker's Wix account
- Correlation across samples identified a coordinated multi-URL campaign targeting Ledger wallet users, which would not have been visible from analyzing any single sample in isolation

8. DETECTION RECOMMENDATIONS

- Implement URL reputation filtering that includes behavioral signals like domain age and registration patterns, not just known-bad lists
- Add content inspection for phishing pages hosted on legitimate platforms — domain reputation alone will not catch Wix, Google Sites, or similar platform-abuse attacks
- Monitor for newly registered domains (less than 30 days old) accessing corporate resources — flag for additional scrutiny
- Block or alert on traffic to high-risk TLDs such as .top, .xyz, .click, and .autos which are disproportionately used in phishing campaigns
- Use multiple OSINT tools in combination — no single tool provides complete coverage
- Report platform-abuse phishing to the hosting provider's abuse team with the CNAME or account identifier as supporting evidence for faster takedown

9. REFERENCES

- PhishTank (Cisco Talos). (2026). <https://phishtank.org>
- VirusTotal. (2026). <https://virustotal.com>
- MXToolbox. (2026). <https://mxtoolbox.com>
- PhishTool. (2026). <https://app.phishtool.com>
- PhishingPot. (2022-2023). Sample phishing emails. https://github.com/rf-peixoto/phishing_pot
- IANA. (2026). WHOIS lookup. <https://who.is>